EWB COURSES

ASSESSMENT 01

SECURITY FOUNDATIONS

AI-POWERED CYBERSECURITY INTERNSHIP

Student Name	Deepak Panwar
Assessment	Assessment 01: Security Foundations
Issued by	EWB Courses | 18 October 2026

FOUR TASKS • 100 MARKS • ONE REPORT

Report prepared from the fictional scenarios and synthetic evidence supplied in the assessment.

TASK A | SECURE A STUDENT ACCOUNT

Scenario: Mira reuses a short password for email and the learning portal, approves unexpected sign-in prompts, delays device updates, stores her only project copy on one laptop, and lets a friend use that laptop while she is signed in.

A1-A2. Risks, assets, CIA impact and controls

Risk	Asset at risk	CIA impact	Practical control	Limitation
1. Reused, short password	Email and learning-portal accounts; messages, coursework and student records.	Confidentiality: someone may read private email or portal data. Integrity: an intruder could change profile or academic information. Availability: lockout may prevent access.	Replace it with a long, unique password for each account; use a password manager.	A password manager must itself be protected, and a strong password cannot prevent phishing or malware.
2. Approving unexpected sign-in prompts	Mira's identity and both accounts.	Confidentiality: an unapproved login may expose messages and files. Integrity: an intruder may change account settings or submissions.	Deny prompts she did not initiate, report repeated prompts, and use phishing-resistant MFA/passkeys or a security key where supported.	MFA is an extra barrier, not a guarantee; push prompts can be abused and recovery methods can be weak.
3. Delayed device updates	Laptop, saved credentials, project files and browser sessions.	Confidentiality: an unpatched flaw may expose files. Integrity: malware may modify work. Availability: malware or a crash may make the laptop unusable.	Install operating-system, browser and application security updates promptly; enable automatic updates.	Updates reduce known vulnerabilities but cannot prevent every attack; compatibility and restart timing may need planning.
4. Only one project copy	Project files and coursework.	Availability: disk failure, theft or ransomware could remove the only copy. Integrity: corruption or unwanted edits may go unnoticed.	Keep versioned backups on a separate external drive or trusted backup service and test restoration.	A backup can also be lost, infected or inaccessible; it must be separate and periodically tested.
5. Friend uses Mira's signed-in account	Email, learning portal, private files and active sessions.	Confidentiality: the friend can see private data. Integrity: accidental or deliberate changes may be attributed to Mira. Availability: settings or files could be altered or deleted.	Lock the screen when away and create a separate standard Windows account for the friend; sign out of sensitive services.	A separate local account does not protect data that Mira has deliberately shared or left accessible elsewhere.

Prioritised first three actions

1. Immediately replace the reused password on the email account and learning portal with different, long, random passwords. Secure email first because it is often used to reset other accounts. CISA recommends long, unique passwords and a password manager.
2. Stop approving unexpected MFA prompts. Deny and report them, review recent sign-ins, revoke sessions that Mira does not recognise, and enable a stronger MFA method such as a passkey or security key if available. This addresses the immediate risk of an attacker using a password and pressuring Mira to approve access.
3. Install pending security updates and turn on automatic updates. This reduces exposure to known software weaknesses. Then create a separate account for the friend and establish a tested backup routine.

A3. Authentication versus authorisation

Authentication answers "Who are you?" When Mira signs in to the learning portal, it checks her identity using her password and a second factor, such as a passkey or authenticator approval. Authorisation answers "What are you allowed to do?" After Mira is authenticated, the portal applies permissions: she may view her own courses, upload assignments and see her own marks, but she should not be able to edit another student's marks or administer the portal. Authentication establishes identity; authorisation controls permitted actions.

TASK B | ANALYSE A SUSPICIOUS MESSAGE

Assessment evidence: The college normally uses campus.example. The message claims to come from awards@campus-awards.example, has Reply-To help@personal-awards.example, imposes a 20-minute deadline, asks for a college password and OTP, tells the student not to contact the college, and requests an identity-card photograph.

B1. Warning signs in the supplied evidence

Warning sign	Relevant quoted phrase	Why it needs scrutiny
1. Sender-domain mismatch	“awards@campus-awards.example”	The known college domain is campus.example. The sender uses a different domain, so the message needs independent verification. A display name or address in the message alone does not authenticate the sender.
2. Unrelated Reply-To	“help@personal-awards.example”	The reply address is on a separate, personal-looking domain. A reply could go to a party unrelated to the college, even if the displayed sender looks official.
3. Artificial urgency	“FINAL WARNING” and “expires in 20 minutes”	A very short deadline pressures the student to act before checking the request. Urgency is a common social-engineering tactic.
4. Credential and OTP request	“enter your college password and OTP”	A scholarship message should not need the student’s password or one-time authentication code. Sharing them could let someone take over the account.
5. Blocks independent checking and asks for ID	“Do not contact the college office” and “Reply with a photo of your identity card”	The message discourages verification through the college and asks for sensitive identity information. These requests increase risk and should not be followed.

B2. Safe verification process

1. Do not click the link, reply, open attachments or provide a password, OTP or identity document. Keep the message for reporting.
2. Open the portal through a trusted bookmark or type the official address from college materials. Alternatively, call or email the scholarship office using contact details found independently in the official college directory - never the Reply-To address.
3. Ask the office to confirm the notice and report the message to the college IT/help desk.

HTTPS encrypts a connection but does not prove that a site belongs to the college; a look-alike site can also use HTTPS. A familiar display name is not proof of sender identity. Independent college confirmation and full email headers provide stronger evidence.

B3. If a student already entered a password and OTP

1. Contact the official college IT/help desk immediately. From a trusted device, change the affected password and any reused password. Never send the password or OTP to support.
2. Ask IT to revoke active sessions/tokens, remove unknown recovery methods or MFA devices, and reset/re-enrol MFA. Secure the linked email account too.
3. Preserve the message, headers, time and displayed link without opening it again. Report it, review sign-in history and account changes, and monitor for misuse of the ID-card image.

B4. What cannot be established from the message alone

The text alone cannot prove who sent the message or who controls the domains. Useful additional evidence would be full headers (including SPF, DKIM and DMARC results) and confirmation from the college through an independently obtained contact. We assess the supplied text; we do not prove that a real sender or site is malicious.

TASK C | TRIAGE A SIGN-IN ALERT

Scope note: All timestamps are IST on 18 October 2026. The assessment states that the IPs are reserved documentation examples and that 192.0.2.10 is the usual classroom egress. A different IP by itself does not identify an attacker.

C1. Four-point timeline: observation versus interpretation

Time	Observed evidence	Interpretation (not a proven fact)
09:00-09:01	192.0.2.10: password success at 09:00; MFA approved at 09:01.	This matches the stated usual classroom egress and is consistent with the student's account of signing in before 09:05. It is the baseline event.
10:14-10:15	198.51.100.23: two password failures.	There were two unsuccessful password attempts from a different source address. This may indicate mistyped credentials or an attempt by someone else; the log alone cannot decide which.
10:16-10:17	198.51.100.23: password success at 10:16; MFA denied at 10:17.	A password was accepted, followed by a denied MFA event. This suggests the password may have been known or entered correctly, but it does not establish who entered it.
10:18-10:20	198.51.100.23: MFA approved at 10:18; session created at 10:20. The student says they approved a prompt to stop repeated requests and did not sign in after 09:05.	The approval was followed by session creation. The student's statement is consistent with an unwanted prompt being approved under pressure, but the logs and statement do not identify the person operating the session.

C2. Likely explanation, alternative and additional checks

Likely explanation: Another person may have had the password and attempted a sign-in. After two failures, the password was accepted; MFA was denied and then approved. The student says they approved a prompt to stop repeated requests. This is consistent with MFA-prompt fatigue or social engineering followed by session creation.

Alternative explanation: A previously connected device or application may have initiated a legitimate sign-in while the network egress changed (for example, due to a VPN or hotspot). This is less consistent with the student's statement, but should be checked.

Two checks that could distinguish them:

- Check identity-provider details for device ID, browser/user-agent, MFA request ID, authentication method and session/token identifiers; compare them with the student's known devices.
- Correlate endpoint and application logs after 10:20 to identify the device and actions taken. Ask about VPN, hotspot or previously connected-device use.

C3. Three prioritised actions for authorised IT

1. Preserve the original identity-provider, MFA and application logs for the relevant period. Retain timestamps, event/request IDs and session identifiers; store records read-only and document who collected them before routine retention removes them.
2. Contain the account: revoke sessions/tokens, restrict access if necessary, reset the password through a trusted process, remove unknown MFA/recovery methods and enrol a secure MFA method. Check and separately secure any linked email account.
3. Review actions taken by the 10:20 session, including account, assignment, file and recovery-setting changes. Notify the student and security staff; restore access only after securing the account and continue monitoring.

C4. Incident summary (60-100 words)

Incident summary: At 09:00-09:01, student07 signed in from the usual classroom egress. At 10:14-10:16, two password failures were followed by password success from another documentation IP. MFA was denied, then approved at 10:18; a session appeared at 10:20. The student says they approved a prompt but did not initiate sign-in. Possible compromise requires preserving logs, revoking sessions and checking devices. The IP does not identify the operator.

TASK D | REVIEW AN AI SECURITY ANSWER

AI output supplied in the assessment: "The email is safe because it uses HTTPS. The sign-in logs prove that the person using 198.51.100.23 stole the password. MFA prevents every account compromise. Delete the suspicious logs and send the student's password to support so they can test it."

D1. Five unsafe or unsupported claims/actions and corrections

AI claim/action	Correction and evidence-based reasoning
1. "The email is safe because it uses HTTPS."	Incorrect. HTTPS encrypts the connection to a site; it does not prove that the domain belongs to the college or that the message is genuine. The message has mismatched sender/Reply-To domains and asks for a password and OTP. Verify independently.
2. "The logs prove that the person using 198.51.100.23 stole the password."	Unsupported attribution. The log shows two failures, a password success, an MFA denial, an MFA approval and session creation from that source IP. It does not identify a person or prove how the password was obtained. An IP may represent a shared, VPN or changing network egress.
3. "MFA prevents every account compromise."	False absolute claim. MFA adds a security layer but is not perfect. The supplied scenario shows an MFA denial followed by approval after repeated prompts. Users should deny unexpected prompts; stronger phishing-resistant methods reduce some risks but do not eliminate every account risk.
4. "Delete the suspicious logs."	Unsafe incident handling. Logs are evidence needed to reconstruct events, determine scope and support a response. Preserve the original records, restrict access and document collection; do not delete or alter them during investigation.
5. "Send the student's password to support."	Never request or disclose passwords or OTPs. Support staff should use an approved password-reset process, revoke sessions, verify identity through official channels and help reconfigure MFA without seeing the secret.

D2. Improved prompt for an AI tool

Prompt to use Analyse only the fictional scholarship-message text and synthetic sign-in log supplied below. Do not browse to or open any URL. Separate (1) directly observed facts, (2) reasonable interpretations and (3) unknowns. Do not identify a person from an IP address or claim that HTTPS proves legitimacy. List the specific warning signs and explain why they matter. For the sign-in events, give one likely explanation and one alternative explanation, then name evidence that could distinguish them. Recommend safe defensive steps only. Do not ask for passwords, OTPs, identity documents or real personal data. State uncertainty clearly and identify which claims need checking against the supplied CISA and NIST references.

D3. Corrected security advice (approx. 120 words)

Do not use the scholarship link or reply to the message. The different sender and Reply-To domains, short deadline, request for a college password and OTP, and request for an identity-card photograph are warning signs. Verify the scholarship through the college portal using a known bookmark or contact the scholarship office using details from the official college directory. HTTPS does not prove that a site is genuine. If you already entered your password or OTP, contact the college IT team immediately from a trusted device, change the affected and reused passwords, revoke active sessions, review recovery and MFA settings, and report the message. Never send a password or OTP to support. Preserve the message and headers for investigation.

D4. AI-USE DECLARATION AND EVIDENCE NOTES

AI-use declaration

AI-use declaration AI assistance used: ChatGPT was used to help organise the assessment responses, explain the supplied fictional evidence and prepare a draft report. The assessment scenarios and synthetic log values were taken from the EWB Assessment 01 PDF. I reviewed the reasoning against the supplied evidence and the references listed below. No real passwords, OTPs, identity documents or private account data were entered. I will review and edit the final wording so it reflects my own understanding.

Two evidence/reference notes

Evidence note 1 - CISA Secure Our World: CISA's Secure Our World guidance recommends strong, unique passwords and a password manager, multifactor authentication, recognising and reporting phishing, and keeping software updated. These recommendations support the controls in Task A and the cautious response in Task B. The guidance does not mean MFA or HTTPS guarantees safety.

Evidence note 2 - NIST AI 600-1: NIST describes "confabulation" as confidently presented erroneous or false generative-AI content and warns that users may be misled by confident wording or fabricated supporting logic/citations. This supports checking the AI answer against the actual log and message evidence instead of accepting its claims. NIST also discusses data-privacy and human-AI over-reliance risks.

References

- EWB Courses. (18 October 2026). Assessment 01: Security Foundations. Supplied assessment PDF, Tasks A-D, pages 1-4.
- Cybersecurity and Infrastructure Security Agency (CISA). Secure Our World - four ways to stay safe online (passwords, MFA, phishing, software updates). https://www.cisa.gov/secure-our-world | CISA tip sheet: https://www.cisa.gov/sites/default/files/2024-09/Secure-Our-World-4-Easy-Ways-Stay-Safe-Online-Tip-Sheet.pdf
- Autio, C., Schwartz, R., Dunietz, J., Jain, S., Stanley, M., Tabassi, E., Hall, P., & Roberts, K. (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile. NIST AI 600-1, especially Section 2.2, "Confabulation." https://doi.org/10.6028/NIST.AI.600-1

Final submission check: Confirm that your name is correct, review the explanations in your own words, and verify that every conclusion is grounded in the fictional assessment evidence. Save the report as EWB_Cyber_Assessment01_Deepak_Panwar.pdf for the official submission form.